ESTRATEGIA DE PRUEBAS: FLUJO DE TRABAJO OPTIMIZADO

1. Definir Alcance y Objetivos Medibles

El objetivo de esta fase es delimitar qué componentes del sistema Cuidarte+ serán auditados en el entorno contenerizado en Docker y establecer criterios de éxito cuantitativos y verificables.

• Delimitación del Alcance:

- En Alcance (In-Scope):

- Autenticación y firmas de tokens JWT (RF-1.1, NFR-SEG-9).
- control de acceso por roles RBAC (Administrador, Médico, Paciente - NFR-SEG-4)
- operaciones CRUD de exámenes y pacientes (RF-3)
- borrado lógico con confirmación (RF-3.3)
- subida/descarga de documentos clínicos PDF (RF-4.3/4.4) y tabla inmutable de auditoría en PostgreSQL (RF-5.1).

- Fuera de Alcance (Out-Scope):

- Integraciones con pasarelas de pago externas, hardware físico médico y facturación electrónica.

• Objetivos Medibles y Criterios de Éxito:

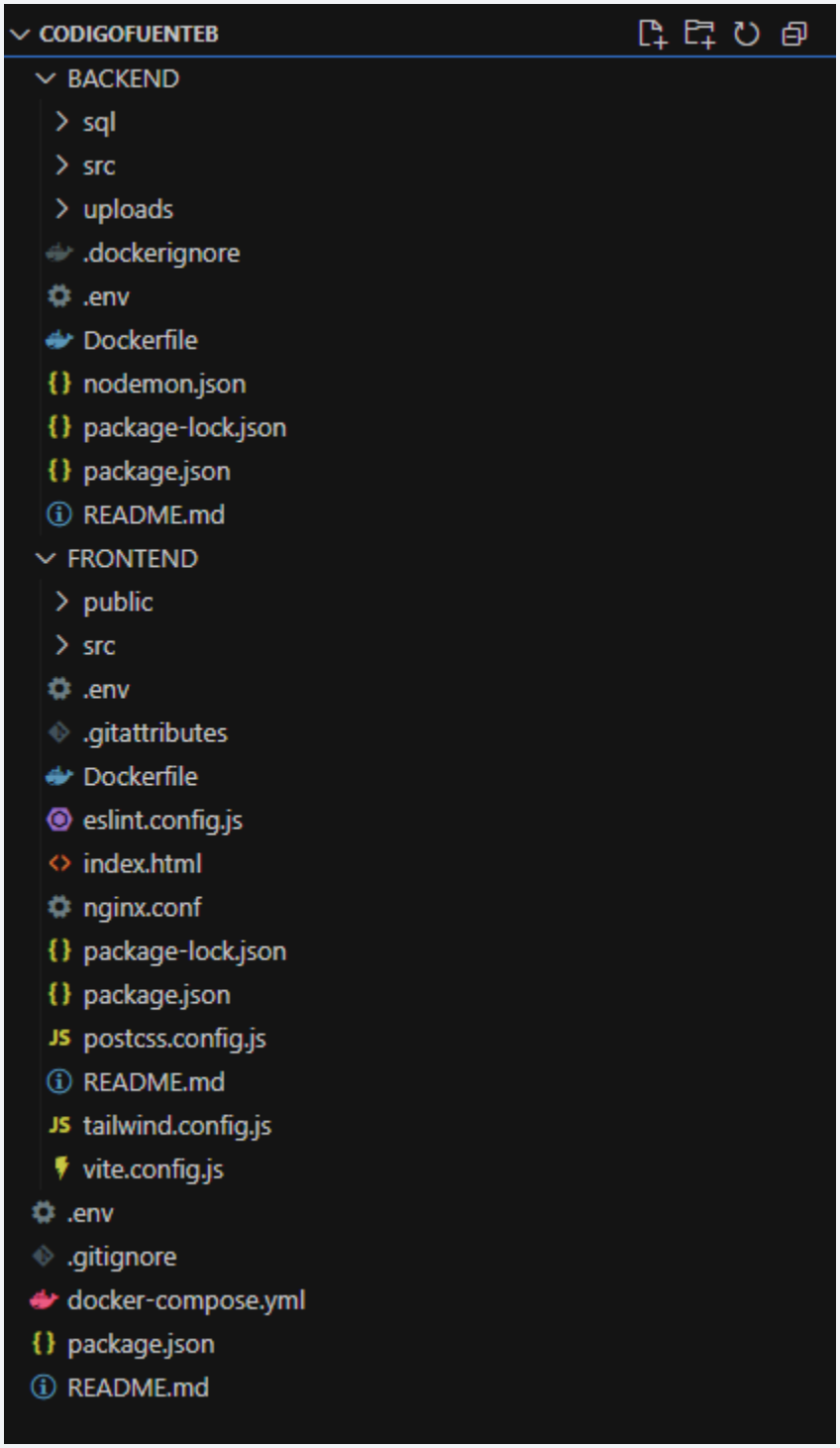
- Rendimiento API: Tiempo de respuesta en endpoints REST menor o igual a 300 ms (NFR-PERF-1) y tiempo de carga de Dashboard menor o igual a 2s (NFR-PERF-2).

- Concurrencia: Soporte garantizado de al menos 200 usuarios concurrentes sin fallos HTTP 5xx (NFR-PERF-3).

- Seguridad: 0 vulnerabilidades de severidad Crítica o Alta en escaneos OWASP ZAP (prevención de SQLi, XSS e IDOR).

- Cobertura y Calidad: Cobertura de código backend mayor o igual al 80% y cumplimiento de accesibilidad WCAG 2.1 AA para adultos mayores (NFR-USAB-1).

Estructura del Proyecto en VS Code



2. Diseñar una Estrategia Basada en Riesgos

Se implementa un enfoque de Risk-Based Testing (RBT) para focalizar los esfuerzos de prueba según la probabilidad e impacto de fallo sobre la operación y el cumplimiento legal chileno.

Nivel de Riesgo	Área Crítica / Módulo	Impacto Potencial	Enfoque de Prueba
Crítico	Seguridad y Privacidad (Datos Sensibles)	Exposición de fichas médicas por vulnerabilidades IDOR/SQLi. Infracción grave a Ley 21.719 y 19.628.	Pruebas DAST con OWASP ZAP, verificación de middlewares RBAC y cifrado.
Alto	Integridad y Auditoría de Datos	Borrado físico no autorizado de exámenes o falta de traza. Infracción a Ley 21.663.	Pruebas de API REST para borrado lógico (deleted_at) y tabla logs_auditoria (RF-5.1).
Medio	Disponibilidad y Carga en Docker	Colapso de contenedores Express/PostgreSQL ante accesos masivos o subidas simultáneas.	Pruebas de Carga y Estrés con Apache JMeter (200 usuarios concurrentes).

3. Planificar Recursos y Cronograma Operativo

• Infraestructura de Entorno: Despliegue mediante docker-compose con 3 servicios aislados: cuidarte-frontend (React), cuidarte-backend (Node.js/Express) y cuidarte-db (PostgreSQL).

• Asignación de Roles:

- QA Lead / DevSecOps (Antonella Cuvertino): Automatización SAST/DAST, pruebas de carga en Docker y análisis de vulnerabilidades.
- Test Architect & Compliance (Miriam Hammami): Diseño de casos IEEE 829, trazabilidad de leyes (21.719 / 21.663) y accesibilidad WCAG.

• Cronograma Operativo (4 Semanas):

- Semana 1: Configuración de entorno Docker, verificación de código fuente y unit tests (Jest).
- Semana 2: Pruebas de integración de API REST (Supertest), RBAC y borrado lógico.
- Semana 3: Pruebas E2E (Cypress), carga masiva en JMeter (200 usuarios) y escaneo OWASP ZAP.
- Semana 4: Pruebas de accesibilidad, informe de evidencias y veredicto de certificación.

Levantamiento de Contenedores Docker



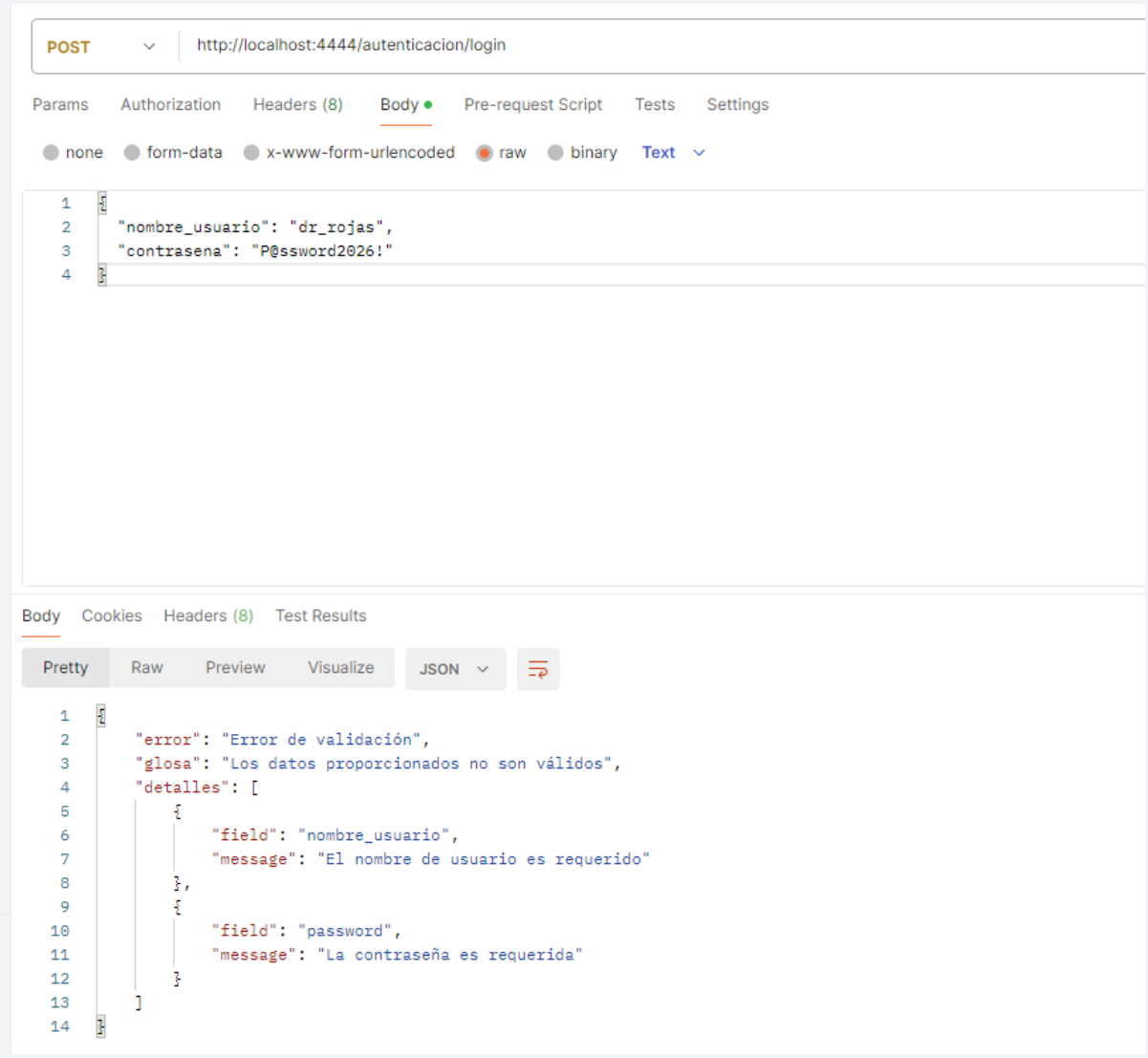

```
cuidarteplus-backend-ev   | GET / 200 3.406 ms - 37
cuidarteplus-backend-ev   | GET /favicon.ico 404 1.369 ms - 150
cuidarteplus-postgres-ev  | 2026-09-22 22:37:21.710 UTC [134] LOG:  invalid length of startup packet
cuidarteplus-postgres-ev  | 2026-09-22 22:37:22.796 UTC [135] LOG:  invalid length of startup packet
cuidarteplus-postgres-ev  | 2026-09-22 22:37:22.799 UTC [137] LOG:  invalid length of startup packet
cuidarteplus-postgres-ev  | 2026-09-22 22:37:22.802 UTC [138] LOG:  invalid length of startup packet
t
cuidarteplus-backend-ev   | POST /autenticacion/registro 201 31.599 ms - 169
cuidarteplus-frontend-ev  | 172.18.0.1 - - [22/Sep/2026:22:37:53 +0000] "GET /assets/logo-jewhTedI.svg HTTP/1.1" 304
t/537.36 (KHTML, like Gecko) Chrome/151.0.0.0 Safari/537.36" "-"
cuidarteplus-backend-ev   | POST /autenticacion/login 200 7.265 ms - 324
cuidarteplus-postgres-ev  | 2026-09-22 22:41:42.393 UTC [71] LOG:  checkpoint starting: time
cuidarteplus-postgres-ev  | 2026-09-22 22:41:49.532 UTC [71] LOG:  checkpoint complete: wrote 74 buffers (0.5%); 0 W
ync files=34, longest=0.004 s, average=0.001 s; distance=270 kB, estimate=270 kB
```

4. Elaborar Casos de Prueba Exhaustivos

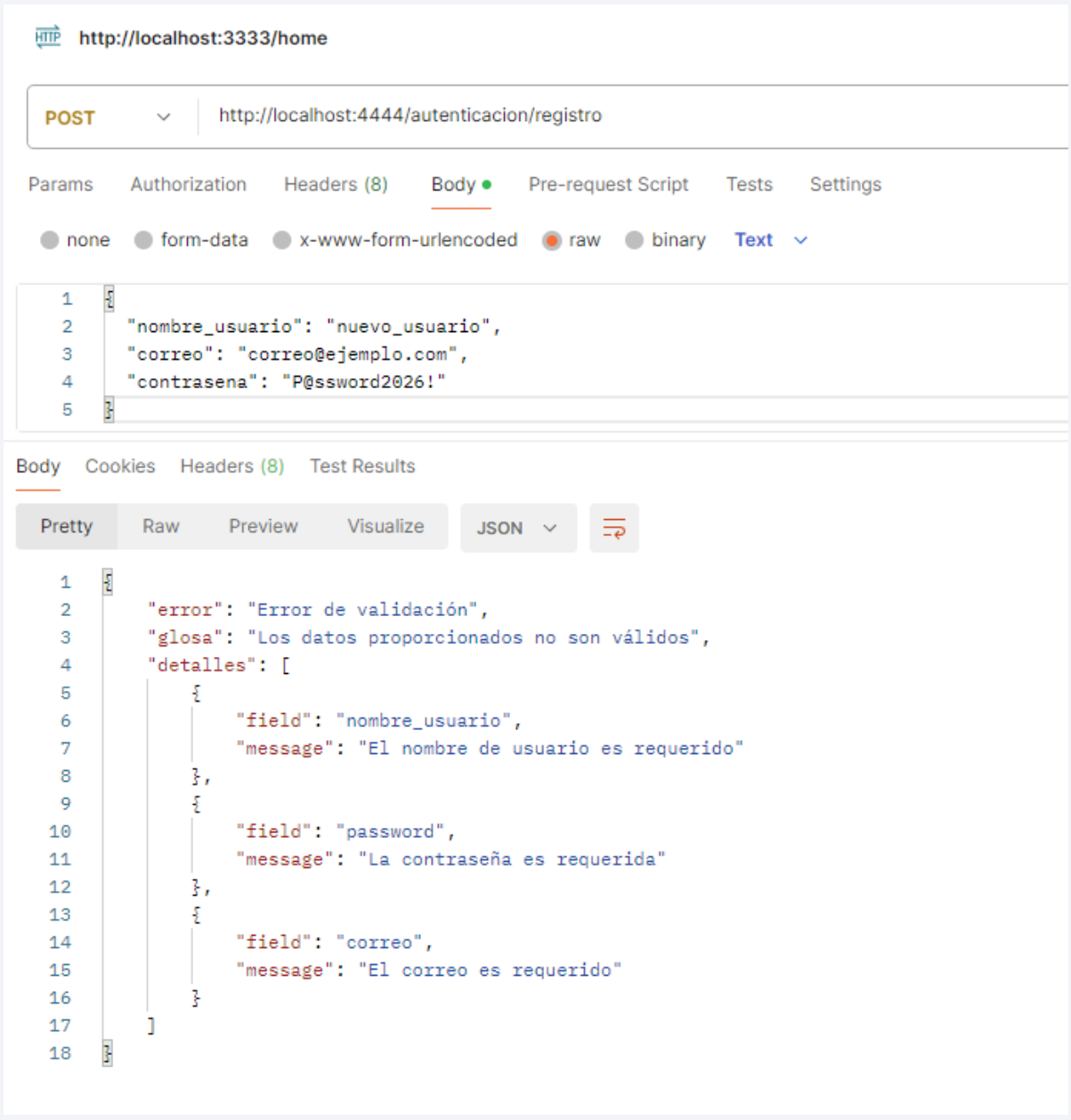
Se estructuran casos de prueba bajo la norma IEEE 829 cubriendo escenarios funcionales, no funcionales y de auditoría:

1. CP-FUNC-001: Autenticación exitosa y generación de JWT de corta vigencia (RF-1.1, NFR-SEG-9).
2. CP-FUNC-002: Registro de examen médico y almacenamiento de adjunto PDF (RF-3.1, RF-4.3).
3. CP-FUNC-003: Eliminación lógica (soft delete) con confirmación explícita (RF-3.3).
4. CP-SEG-001: Sanitización de entradas contra Inyección SQL en búsqueda (NFR-SEG-5).
5. CP-SEG-002: Validación de middleware RBAC e intento de acceso no autorizado IDOR (NFR-SEG-4).
6. CP-PERF-001: Prueba de carga masiva con 200 usuarios concurrentes en JMeter (NFR-PERF-3).
7. CP-CUMP-001: Verificación de registro inalterable en logs_auditoria ante edición de rol (RF-5.1, Ley 21.663).

Ejecución de Pruebas Automatizadas / Endpoint
Prueba de inicio sesión :



Prueba registro usuario:



Documentacion swagger:

lista completa de todos los endpoints disponibles en el backend y los parámetros que requiere cada uno

